

Don't allow update_into to mutate immutable objects #8230

New issue

Merged

 reaperhulk merged 1 commit into `pyca:main` from `alex:dont-mutate-me-bro` on Feb 8, 2023

Conversation 6

Commits 1

Checks 0

Files changed 2

+9 -1

alex commented on Feb 8, 2023

Member

No description provided.

Don't allow update_into to mutate immutable objects

Unverified

94a50a9

reaperhulk approved these changes on Feb 8, 2023

View reviewed changes

reaperhulk enabled auto-merge (squash) 3 years ago

reaperhulk merged commit 9fbf84e into pyca:main on Feb 8, 2023

alex deleted the dont-mutate-me-bro branch 3 years ago

reaperhulk pushed a commit to reaperhulk/cryptography that referenced this pull request on Feb 8, 2023

Don't allow update_into to mutate immutable objects (pyca#8230)

b35ad89

alex added a commit that referenced this pull request on Feb 8, 2023

changelog + security fix backport (#8231)

Verified

d6951dc

Reviewers

reaperhulk

✓

Assignees

No one assigned

Labels

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

3 participants



zhuofeng6 commented [on Feb 17, 2023](#)

Does this involve interface changes?



reaperhulk commented [on Feb 17, 2023](#)

Member

It behaves exactly the same unless you were passing an immutable type (e.g. a byte string). So the interface has technically changed but in practice it has only changed for the vulnerable path.



zhuofeng6 commented [on Feb 17, 2023](#)

In this case, change the buf class type from `bytes` to `bytearray`. it is OK?

it can't use the `bytes` type anymore.

```
def update_into(self, data: bytes, buf: bytes)
```



zhuofeng6 commented [on Feb 17, 2023](#)

I'm not sure what the effect of this vulnerability is.



reaperhulk commented [on Feb 17, 2023](#)

Member

Unfortunately the Python type hint system doesn't have a way to represent "all objects that implement the buffer protocol but only the mutable types", so `bytes` is still the closest to "correct" type that we can declare.



zhuofeng6 commented [on Feb 21, 2023](#)

What is the impact of this cve? I don't seem to feel the threat of this vulnerability.



icanhasmath added a commit to [ActiveState/cryptography](#) that referenced this pull request [on Jan 18, 2024](#)

 Cherry-pick fix for [CVE-2023-23931](#) 6b20296
from ([pyca#8230](#)) ...



icanhasmath added a commit to ActiveState/cryptography
that referenced this pull request on Jan 18, 2024

 Cherry-pick fix for [CVE-2023-23931](#) 9626647
from ([pyca#8230](#)) ...